



CYBER); CRA; Cybersecurity requirements for software that searches for, removes, or quarantines malicious software

CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit : <https://labs.etsi.org/rep/stan4cra/en-304-619> and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](https://docbox.etsi.org/CYBER/EUSR/OpenConsultation.xlsx)” available in [https://docbox.etsi.org/CYBER/EUSR/Open](https://docbox.etsi.org/CYBER/EUSR/OpenConsultation.xlsx)

Reference

DEN/CYBER-EUS-0018

Keywords

antivirus, antimalware, security requirements,

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

Reproduction is only permitted for the purpose of standardization work undertaken within ETSI.
The copyright and the foregoing restrictions extend to reproduction in all media.

© ETSI 2025.
All rights reserved.

Contents

Intellectual Property Rights	6
Foreword.....	6
Modal verbs terminology	6
Executive summary	7
Introduction	7
1 Scope	8
2 References	8
2.1 Normative references.....	8
2.2 Informative references	8
3 Definition of terms, symbols and abbreviations.....	9
3.1 Terms	9
3.2 Symbols	9
3.3 Abbreviations.....	10
4 Product context.....	10
4.1 General.....	10
4.2 Essential functionalities	10
4.3 Security Category Levels.....	11
4.3.1 General	11
4.3.2 Minimal Security.....	12
4.3.3 Medium Security	12
4.3.4 High Security	12
4.4 Identified Threats.....	12
4.4.1 Threats to Update and Signature Integrity.....	12
4.4.2 Threats to Core Components and Self-Protection	12
4.4.3 Threats to Communication and Data Exchange	13
4.4.4 Supply Chain and Third-Party Component Threats	13
4.4.5 Advanced Threat Actor Techniques.....	13
4.4.6 User-Facing Threats	13
4.5 Risk Factors	13
4.5.1 General	13
4.5.2 RF1 - Size.....	13
4.5.3 RF2 - Lack of Software Maintenance Knowledge	14
4.5.4 RF3 - Data Sensitivity	14
4.5.5 RF4 - Remote Work	14
4.5.6 RF5 – Use of public Wi-Fi.....	14
4.5.7 RF6 - Use of removable storage devices.....	14
4.6 Intended purpose and reasonably foreseeable use	15
4.6.1 Identified Use Cases.....	15
4.6.1.1 UC1: Systems with Performance Constraints or Trusted Environments.....	15
4.6.1.2 UC2: General-purpose Environments.....	15
4.6.1.3 UC3: High-risk Server Environments	15
4.6.1.4 UC4: High-risk Laptops Environments	15
4.6.1.5 UC5: Tailored Environments.....	15
4.6.1.6 UC6: Mobile Communication Devices.....	16
4.6.2 Use cases to risk factors and risk levels mapping	16
4.7 Architecture	16
4.8 Operational Environment.....	18
4.8.1 Logical Operational Environment:.....	18
4.8.2 Physical Operational Environment:.....	18
4.8.3 Chain of Trust	18
4.9 Users	20
4.9.0 Introduction	20
4.9.1 Common Users (Personal Desktops).....	20

4.9.2	Enterprises (Private Data)	20
4.9.3	Public Administration (Private Data Used for Public Purposes).....	20
5	Requirements specifications.....	21
5.1	Introduction.....	21
5.2	Security Requirements.....	21
5.2.1	General	21
5.2.2	Known Exploitable Vulnerabilities	21
5.2.2.1	Mapping of Requirements Applicability to the UCs and SCLs.....	21
5.2.3	Secure by Default Configuration.....	22
5.2.3.1	Mapping of Requirements Applicability to the UCs and SCLs.....	22
5.2.4	Security Updates	22
5.2.4.1	Mapping of Requirements Applicability to the UCs and SCLs.....	23
5.2.5	Authentication and Access Control.....	23
5.2.5.1	Mapping of Requirements Applicability to the UCs and SCLs.....	23
5.2.6	Confidentiality Protection	24
5.2.6.1	Mapping of Requirements Applicability to the UCs and SCLs.....	24
5.2.7	Integrity Protection.....	24
5.2.7.1	Mapping of Requirements Applicability to the UCs and SCLs.....	24
5.2.8	Data Minimization	24
5.2.8.1	Mapping of Requirements Applicability to the UCs and SCLs.....	25
5.2.9	Availability Protection	25
5.2.9.1	Mapping of Requirements Applicability to the UCs and SCLs.....	25
5.2.10	Impact minimization	25
5.2.10.1	Mapping of Requirements Applicability to the UCs and SCLs.....	25
5.2.11	Secure by Design.....	25
5.2.11.1	Mapping of Requirements Applicability to the UCs and SCLs.....	26
5.2.12	Exploitation Mitigation Mechanisms and Techniques	26
5.2.12.1	Mapping of Requirements Applicability to the UCs and SCLs.....	26
5.2.13	Logging and Monitoring Mechanisms	26
5.2.13.1	Mapping of Requirements Applicability to the UCs and SCLs.....	27
5.2.14	Data Removal and Transference Mechanisms	27
5.2.14.1	Mapping of Requirements Applicability to the UCs and SCLs.....	27
5.3	Vulnerability Handling Requirements	27
5.3.1	General	27
5.3.2	Product Dependencies	27
5.3.3	Vulnerabilities Remediation.....	27
5.3.4	Effective and Regular Testing.....	27
5.3.5	Security Updates Availability	27
5.3.6	Vulnerability Disclosure Policies.....	27
5.3.7	Information Sharing	27
5.3.8	Securely Update Distribution Mechanisms	27
5.3.9	Security Updates Dissemination	27
6	Assessing for compliance with requirements.....	27
6.1	General.....	28
6.2	Security Requirements Assessment	28
6.2.1	Known Exploitable Vulnerabilities	28
6.2.2	Secure by Default Configuration.....	29
6.2.3	Security Updates	30
6.2.4	Authentication and Access Control.....	31
6.2.5	Confidentiality Protection	32
6.2.6	Integrity Protection.....	33
6.2.7	Data Minimization	34
6.2.8	Availability Protection	34
6.2.9	Impact minimization	34
6.2.10	Secure by Design.....	35
6.2.11	Exploitation Mitigation Mechanisms and Techniques	36
6.2.12	Logging and Monitoring Mechanisms	36
6.2.13	Data Removal and Transference Mechanisms	37

Annex A (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847.....	38
Annex B (informative): Information on the methodology for the assessment of cybersecurity risks used to develop the present document	39
B.1 Principles and references.....	39
B.2 Risk model	39
B.3 Identify Threats and RFs	40
B.4 Risk criteria	40
B.4.1 Risk Likelihood (L)	40
B.4.2 Magnitude of loss or disruption (M).....	40
B.4.3 Qualitative risk matrix	40
B.4.4 Quantitative scoring and aggregation	41
B.5 Process:	41
B.6 CM & CE calibration by use case and security level	42
B.6.1 About the CM	42
B.6.2 About the CE	42
B.7 Example.....	43
Annex C (informative): Use Cases Risk Assessment	44
C.1 UC1: Systems with Performance Constraints or Trusted Environments	44
C.2 UC2: General-purpose Environments	44
C.3 High-risk Servers Environments	44
C.4 High-risk Laptops Environments	45
C.5 Tailored Environments.....	45
C.6 Mobile Phones.....	45
Annex D (informative): Current virus and malware examples.....	46
Annex E (informative): Relationship between the present document and any related ETSI standards (if any)	48
Annex F (informative): Bibliography	49
Annex F (informative): Change history.....	50
History	51

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER).

The present document has been prepared under the Commission's standardisation request C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 [i.1] known as the Cyber Resilience Act (CRA). It corresponds to the new deliverable in **line 19** of Annex I of the standardisation request.

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

"Executive summary" clause should be deleted if not necessary.

[It will be done, once the first stable draft is completed and before submitting it]

Introduction

The present document defines cybersecurity requirements applicable for any kind of software that searches for, removes, or quarantines malicious software. It applies to products with digital elements designed to identify and detect possible threats that may affect the performance of other products with digital elements and/or the underlying software.

The present document supports compliance with Regulation (EU) 2024/2847, the Cyber Resilience Act, specifically addressing the essential cybersecurity requirements defined in Annex I, Parts I and II. The mapping of the minimum CRA requirements with the technical requirements of the present document are explicitly detailed in Annex A.

1 Scope

The present document specifies the security requirements for software products with digital elements typically referred to as antivirus or antimalware, that detect or search for malicious software or code on a device, or remove or quarantine such software or code to prevent or mitigate system infection.

In the context of this category of products, malicious software means software designed with malicious intent containing features or capabilities that can potentially cause harm directly or indirectly to the user and/or the user's digital product, such as viruses, worms, ransomware, spyware and trojans.

This category of products includes but is not limited to software that detects or searches for malicious software in real-time or manually, rootkit detection and rescue disks with the core functionality of searching, removing or quarantining malicious software.

Among the identified products with digital elements that fall into the previous description are:

- Antivirus
- Antimalware

which are described in **Clause 4** "Product Context".

With the key objective to place products securely on the market, the present document provides the following information:

- the set of minimum use cases in which the PwDE should accomplish;
- the risk analysis associated with the previous use cases and security requirements that the PwDE should take into account;
- the security requirements for the PwDE;
- the assessment criteria associated with the PwDE.

The present document covers those products to demonstrate compliance with requirements in the EU Regulation 2024/2847 under the conditions identified in **Annex A**.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

[1] <Standard Organization acronym> <document number> (<version number>): "<Title>".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding but are not required for conformance to the present document.

- [i.1] [Regulation \(EU\) 2024/2847](#) of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (Text with EEA relevance).
- [i.2] Commission Implementing Regulation (EU) [.../...of XXX](#) on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council (Text with EEA relevance)
- [i.3] [C\(2025\)618 – Standardisation request M/606](#): Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)
- [i.4] ISO/IEC 27001: "Information Security Management Systems".
- [i.5] ISO/IEC 15408: "Common Criteria".

3 Definition of terms, symbols and abbreviations

3.1 Terms

RAPPORTEUR NOTE: Ref for terms definitions: [L_202402847EN.000101.fmx.xml](#)

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 and the following apply:

heuristic analysis: behavioural pattern recognition for unknown threats

malware: malicious software designed to disrupt, damage, or gain unauthorized access

principle of least privilege: every user, process, service, and component gets only the minimum access (permissions, data, time, and network reach) needed to do its job with the goal to shrink attack surface and limit blast radius if something is compromised

protected system: system protected by the antivirus or antimalware products in the scope of the present document

quarantine: isolation of suspected threats

signature-based detection: identification using known malware fingerprints

update mechanism: process to retrieve and verify new signatures or detection logic

virus: type of malware specifically designed to self-replicate by injecting its own code into other programs code files

3.2 Symbols

For the purposes of the present document, the [following] symbols [given in ... and the following] apply:

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

APT	Advanced persistent threats
C2	Command and Control
CC	Common Criteria
CRA	Cyber Resilience Act
EDR	Endpoint Detection and Response
HSM	Hardware Security Module
IAM	Identity and Access Management
ISO	International Organization for Standardization
MITM	Man-In-The-Middle
NIST	National Institute of Standards and Technology
PIA	Privacy Impact Assessments
PII	Personally Identifiable Information
PoLP	Principle of Least Privilege
PwDE	Product with Digital Elements
SBOM	Software Bill of Materials
SDK	Software Development Kit
SIEM	Security Information and Event Management
TLS	Transport Layer Security
TUF	The Update Framework
XDR	Extended Detection and Response

4 Product context

4.1 General

The present document defines cybersecurity requirements for products whose primary purpose is searching for, removing, or quarantining malicious software. The present document does not substitute but complements the CRA document [i.1] with the main focus on the following PwDE:

Antivirus: Software application focused on scanning devices for known viruses to remove or quarantine it. Its performance is based on the use of signature-based detection (i.e. comparing files to a database of known malware signatures). Its main limitations are to be less effective against zero-day attacks or sophisticated malware that evades signature-based detection.

Antimalware: Software application with an extended antivirus capacity towards the protection of a wider range of malicious software (e.g. Trojans, spyware, and ransomware). Its performance, compared to antivirus, is extended by combining signature-based, behaviour-based, and sometimes heuristic analysis. Limited to highly advanced and evasive malware.

Other possible PwDE that integrate the above-defined Antivirus or Antimalware component, may use the present document as a reference. For example, a SIEM including any of the previous two previous PwDE may follow the requirements defined in the present document and those identified in its corresponding standardization document [REF SIEM WI]. When necessary, these possible relationships are identified in the following clauses and clauses of the present document.

4.2 Essential functionalities

Any standalone PwDE described in clause 4.1 or other PwDE integrating PwDE described in clause 4.1 typically includes the following essential functionalities:

Virus Detection: The PwDE supports detection of viruses through signature-based methods, which involve identifying known virus patterns and matching them against files and processes on the database. This database is regularly updated to ensure that new and evolving virus threats are recognized.

Malware Detection: The PwDE supports a multi-layered approach for malware detection, including:

- **Signature-based Detection:** Identifying known malware threats by matching their specific patterns or signatures with the files or processes under examination.
- **Behaviour-based Detection:** Monitoring the behaviour of programs and processes in real-time to identify malicious actions or anomalies that resemble the behaviour of malware, even in the absence of a known signature.
- **Heuristics-based Detection:** Using heuristic algorithms to analyse files and programs for potentially harmful or suspicious characteristics, thereby detecting previously unknown or zero-day threats.

Threat Management: Upon detection of a virus or malware, the PwDE provides the following management options:

- **Quarantine:** The capability to isolate infected files or processes in a secure area to prevent further infection or damage to the system.
- **Removal:** The capability to safely and completely remove detected viruses or malware from the system, ensuring no residual malicious code remains.
- **Notification:** The capability to notify the user of any detected threats and the actions taken (e.g. quarantine or removal), and provide the option for the user to review, approve, or reject the suggested actions.

Continuous Monitoring and Updates: The PwDE includes a mechanism for continuous monitoring of the system for new and emerging threats, with automatic or user-initiated updates of threat signatures, behaviour models, and heuristic algorithms to adapt to evolving security risks.

These functionalities are crucial for providing a comprehensive defence against the continuously evolving viruses and malware landscape, ensuring system integrity, user privacy, and data protection.

4.3 Security Category Levels

4.3.1 General

The present document establishes three cumulative Security Category Levels (SCLs) so that CRA security obligations can be applied proportionately to risk and a fourth one to allow PwDE manufacturers to offer their PwDE under a specific SCL with additional security capabilities from higher SCLs. These levels define the applicable requirements depending on the product's intended use.

The proposed SCLs are not isolated one from each other, but they have dependencies among them as illustrated in Figure 1. Minimal Security allows to achieve a basic set of security needs, Medium Security considers the needs defined in the Minimal Security and extends them with updates or new needs, High Security does the same by enhancing the needs from Medium Security and considering more demanding needs. Finally, the Custom Security is proposed to give the possibility to the PwDE manufacturers to define a more tailored SCL for their PwDE, in case of using the "Custom Security", the PwDE manufacturer may clearly identify one of the three SCLs and should describe which needs are covered from the other SCLs.

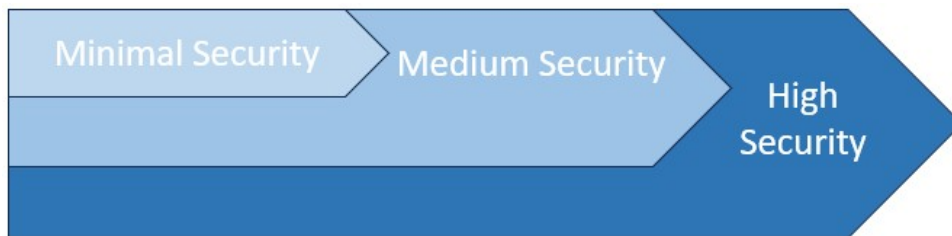


Figure 1: SCLs relationships

4.3.2 Minimal Security

Minimal security implies that the PwDE may be offered as a standalone product with a set of protection capabilities based on the simplest technologies to detect malware such as signature-based detection (e.g. computer viruses in **Annex D**) and frequent data-based updates should be implemented.

4.3.3 Medium Security

Medium Security implies that the PwDE may be offered as a standalone product that builds on the capabilities defined in the Minimal Security and extends them to address threats and risks considered to belong to the UC2. At this level, enhanced detection technologies (i.e. heuristics) should work together with those in the Minimal Security. Real-time data-based updates should be available as soon as a vulnerability mitigation is available to keep the end-user securely updated. In this level of security, the PwDE may deliver all the antivirus and anti-malware protection technologies known such as signature-based, behaviour-based and heuristics-based detection, increasing the possibilities that any type of malware may be detected and its threat mitigated.

4.3.4 High Security

High security implies that the PwDE may be offered as a standalone product with the same conditions as the Medium Security, and additional requirements to deliver a more complete security to the PwDE user are necessary as more sophisticated threats such as APTs may be expected. To this end, requirements to interact and/or cooperate with other PwDEs and protect these interactions need to be considered, increasing the complexity of this level.

A potential cooperation that may occur to achieve this SCL is the following: the integration of an antivirus/antimalware PwDE with SIEM PwDE (i.e. to collect, aggregate, and analyse large volumes of data), EDR/XDR PwDE (i.e. to help organizations detect, investigate, and respond to security incidents), Firewalls PwDE (i.e. to block the malicious traffic), etc.

It is key to clarify that the present document focuses on the security requirements of the PwDE defined in Clauses 4.1 and 4.2 and the previous was an example aiming to assist the reader on understanding the current SCL. To this end, the combination of components above is a possible example of many, and so, each PwDE manufacturer should identify which type of relationships and/or integrations its antivirus/antimalware PwDE needs with other possible PwDE components towards placing its aggregate PwDE on the market. In either case, whether the PwDE is placed in the market in a standalone or as a component of another PwDE, the security requirements defined in the present document need be accomplished.

4.4 Identified Threats

The following security threats have been identified as relevant for antivirus and antimalware software PwDE. Manufacturers shall assess, mitigate, and validate these threats to ensure compliance with the present document based on the identified threats below and the security requirements in Clause 5.

The identified threats are grouped into categories addressing update integrity, self-protection, communication, supply chain dependencies, advanced attack techniques, and user interaction.

4.4.1 Threats to Update and Signature Integrity

Tampered Signature Database: An attacker modifies or replaces malware signature files to disable detection or trigger false detections.

Compromised Update Packages: Attackers distribute malicious or altered updates (e.g. through MITM attacks or compromised servers).

Rollback Attacks: Forcing the PwDE to install an outdated and vulnerable version of the database or engine.

4.4.2 Threats to Core Components and Self-Protection

Disabling or Bypassing Protection Modules: Malware or attackers attempt to terminate processes, alter configuration files, or unload critical drivers of the PwDE.

Tampering with Quarantine Mechanisms: Malicious code attempts to restore quarantined files or execute them despite isolation.

Privilege Escalation on PwDE Services: Exploiting flaws in the antivirus engine to gain elevated privileges (e.g. kernel-level exploitation of scanning drivers).

4.4.3 Threats to Communication and Data Exchange

MITM Attacks on Cloud Connections: Interception or injection of data between PwDE and its secure cloud backend.

Compromised Threat Intelligence Feeds: Malicious or spoofed intelligence data leading to false decisions (e.g. whitelisting malicious files).

Leakage of Sensitive Data: Improper handling of logs, telemetry, or threat reports leading to unauthorized disclosure of PII or sensitive system data.

4.4.4 Supply Chain and Third-Party Component Threats

Malicious Third-Party Libraries: Insertion of vulnerable or intentionally compromised open-source components in the PwDE.

Trojanized Distribution Channels: Attackers compromise the vendor's distribution platform to deliver rogue installers.

SBOM Manipulation: Inaccurate or incomplete SBOM leading to unassessed dependencies.

4.4.5 Advanced Threat Actor Techniques

Zero-Day Exploitation of the PwDE: Exploiting unpatched vulnerabilities in scanning engines or update logic.

Evasion Attacks: Polymorphic, metamorphic, and fileless malware designed to avoid detection or exploit the PwDE itself.

Insider Threats: Malicious use of privileged access to disable, misconfigure, or backdoor the PwDE.

4.4.6 User-Facing Threats

Rogue or Fake Antivirus Products: Malicious software masquerading as legitimate PwDE, tricking users into installation.

Social Engineering to Disable Protection: Attackers trick users into turning off updates, real-time protection, or whitelisting malicious files.

Misleading Notifications: Exploited UI messages prompting users to execute unsafe actions.

4.5 Risk Factors

4.5.1 General

As an antivirus/anti-malware is a developed software that aims to access an organization's information or resources to trigger more dangerous situations, the following risks factors (RF) have been identified to define possible angles from where an organization may be attacked to overpass a virus/anti-malware.

4.5.2 RF1 - Size

Despite large organizations are thought to be the entities receiving the biggest attacks due to their massive and multination structure, they are also the entities with more resources to acquire and implement high-security tools and protections layers within their protected systems. Nowadays, attackers target smaller entities that still manage or access protected data but may not have enough cybersecurity resources or staff as large entities to protect all their

infrastructure. In this risk, the aspects to be considered to assign a risk likelihood to happen and the magnitude of loss or disruption shall vary on whether the affected PwDE protects an individual or a small, medium and large organization.

4.5.3 RF2 - Lack of Software Maintenance Knowledge

In many organizations, software maintenance is coordinated through a centralized and dedicated IT team that inventories systems, evaluates vendor releases, and schedules deployments so that updates are introduced in a controlled manner across the infrastructure. Other entities (i.e. small enterprises, general public, etc.) may not have a permanent IT staff. In these environments, the decision to install an update is frequently deferred to individual teams or, even, end users with no experience. The result is uneven adoption: some systems are promptly refreshed while others remain on older builds because the users are occupied with primary duties, do not perceive the urgency of a security fix, or are unsure whether the change could disrupt their workflow. The character of the software itself has a strong influence on how quickly it can be brought up to date. Actively supported products typically follow a predictable release cadence and provide patches through established channels. By contrast, legacy applications, bespoke solutions, and firmware-dominated platforms (including certain OT/IoT devices and appliances) may receive updates irregularly (or non), once they pass into extended support or end-of-life. Where updates exist, they may require specialized procedures, downtime, or vendor involvement, which slows their uptake. In this risk, the aspects to be considered to assign a risk likelihood to happen and the magnitude of loss or disruption shall vary on whether the affected PwDE maintenance is done by a dedicated IT team, and individual team with certain experience or just by a final user with no experience.

4.5.4 RF3 - Data Sensitivity

The type of information an organization handles directly influences its exposure to cyber threats. Data sets that include rich personal or financial details (e.g. full identifiers, account numbers, national IDs, etc.) are more attractive to be targeted and carry greater potential harm if compromised than basic contact lists containing only names and mailing addresses. Understanding the sensitivity of the managed data requires is key and classifying data according to its business value and potential impact if lost, altered, or disclosed, will allow to identify the necessary protection. In this risk, the aspects to be considered to assign a risk likelihood to happen and the magnitude of loss or disruption shall vary on the whether protected system is within the organization premises or not, as in many organizations together with the antivirus/anti-malware products there are other PwDEs increasing the security of the system (e.g., port filtering, etc.).

4.5.5 RF4 - Remote Work

Remote work delivers flexibility and allows many organizations or users to continue operating and working through disruption. But, once employees perform their duties off-site (i.e. laptops or phones), the protected devices are more difficult to be controlled as the attack surface extends beyond the corporate network. In this risk, the aspects to be considered to assign a risk likelihood to happen and the magnitude of loss or disruption shall vary on the whether protected system is within the organization premises or not, as in many organizations together with the antivirus/anti-malware products there are other PwDEs increasing the security of the system (e.g., port filtering, etc.).

4.5.6 RF5 – Use of public Wi-Fi

Public Wi-Fi should be treated as a hostile environment. When a laptop or phone connects to an open network, it is key to assume that anything sent or received could be monitored or tampered with. Instead, private Wi-Fi networks are assumed to be more secure due to the closeness of the network. In this risk, the aspects to be considered to assign a risk likelihood to happen and the magnitude of loss or disruption shall vary on whether the protected system is connected to the internet through a public access network (e.g., bar/restaurant Wi-Fi), a private personal network (e.g., home or personal business Wi-Fi) or a private company (i.e., limited access for external users to access it).

4.5.7 RF6 - Use of removable storage devices

The use of removable storage devices like external hard disks or USB memories may become an important attack surface if the origin is not known, and still they can be easily manipulated in short periods of time if not well protected. For this reason, a virus or a malware may be placed in them waiting for a connection with a server, laptop of personal computer to place themselves into the new device. In this risk, the aspects to be considered to assign a risk likelihood to happen and the magnitude of loss or disruption shall vary on whether the user managing the protected system can make use of any type of removable storage devices, only specific storage devices or no use at all.

4.6 Intended purpose and reasonably foreseeable use

4.6.1. Identified Use Cases

This clause should be used by any developed PwDE intending to use to the present document to identify the Use Case (UC) it belongs based on the defined aspects below. For each UC, a set of minimum features that the PwDE manufacturer may take into consideration are presented, together with the associated risk that may appear. In addition, a set of possible/potential supply chain interactions with other standardised PwDEs is proposed as an informative aspect in order for the PwDE manufacturers to take into consideration when possible at the time of their product development and possible requirements needed to interact with these potential PwDEs.

4.6.1.1 UC1: Systems with Performance Constraints or Trusted Environments

UC1 refers to scenarios where the protected system has a limit in terms of resources (i.e. energy access, processing resources, etc.) and/or the threats have limited ways to reach the protected system as the environment may be considered as trustworthy. Possible examples of this kind of scenarios may be an isolated virtual machine that is hosted by a trusted underlying virtualization product or an IoT device that needs to control its energy consumption by not having constant processes running automatically.

4.6.1.2 UC2: General-purpose Environments

UC2 refers to scenarios where protected system is used for everyday productivity and personal tasks on mainstream operating systems and hardware. Threat exposure is broad (web browsing, email, messaging, downloads, and removable media), software inventories change frequently, and users may have varying privilege levels. Connectivity is typically continuous and updates are pulled from public networks. In this context, the PwDE should balance strong protection with usability and performance, minimize false positives, and safeguard user privacy. Typical examples include office desktops and laptops, home PCs and laptops, and university workstations shared by non-expert users.

4.6.1.3 UC3: High-risk Server Environments

UC3 refers to scenarios where the protected systems, managed by cybersecurity experts, handle sensitive data, safety-critical processes, or mission-critical operations and are targeted by capable adversaries. These environments feature strict change control, segmented networks, and rigorous audit/compliance requirements. Availability and integrity are paramount; detection efficacy and tamper resistance outweigh convenience. The PwDE should operate with hardened configurations (e.g. self-protection, signed updates, deterministic policies), support offline or staged updates, and provide trustworthy telemetry and forensics. Examples include servers within industrial entities or public administrations with high security measures but with wider range of threats.

4.6.1.4 UC4: High-risk Laptops Environments

Closely related to UC3, UC4 refers to the same scenarios (i.e. protected systems handle sensitive data, safety-critical processes, mission-critical operations, etc.) but the protected systems are used by non-expert cybersecurity users. Despite the protected systems may probably be managed under strict protocols defined by the organization owning the protected device, non-expert users are still a possible and important attack surface to the protected device. Examples include payment processing workstations, administrative consoles defence secure enclaves, clinical systems handling patient data, and critical infrastructures.

4.6.1.5 UC5: Tailored Environments

UC5 refers to scenarios where the protected system requires high configurability and tight integration with enterprise tooling. Policies are tailored per role, business unit, or tenant; exceptions are managed through formal workflows; and security operations teams demand granular control over detection logic, response actions, and telemetry. The PwDE should expose robust management interfaces and APIs, support scripted/automated deployments, be tailored integrated with SIEM/EDR/SOAR, and enable controlled performance tuning on servers and developer workstations. Examples include large enterprises with centralized SOC, regulated organizations needing custom reporting, and advanced users who maintain curated allow/deny lists and bespoke scanning schedules.

4.6.1.6 UC6: Mobile Communication Devices

UC6 refers to the scenario where the protected system is a mobile device, especially a smartphone, tablets, smartwatch or smart ring, which concentrate personal (e.g. banking apps, MFA tokens, email, photos, microphones/cameras, VPN profiles). Threat exposure is wide: application distribution platforms and sideloading, malicious SDKs within legitimate apps, web/phishing (e.g. smishing, QR codes), risky Wi-Fi, malicious configuration profiles, screen-locker ransomware, and credential-stealing overlays. Platform constraints (e.g. battery, CPU, background-task limits, and OS sandboxing) plus fragmented patching make a dedicated PwDE layer important to prevent compromise and contain impact.

Note: A key aspect in this UC is where the source of the PwDE is located; usually all the applications for smartphones, smartwatches and similar devices are available in specific store-based platforms where users may acquire (for free or not) many different applications. These platforms may be owned by the same PwDE vendor or by a third-party entity.

4.6.2 Use cases to risk factors and risk levels mapping

INFO: Initial proposal, this content might/will be updated when the previous Clauses are stable.

This clause presents the mapping of the UCs with the risk and security levels, together with the possible specific examples of programming viruses and malware identified in Annex D.

Table 1: Mapping of the use cases to the risk levels and the SCL

UC	Representative Threat (Clause 4.4)	Risk Assessment Classification (Annex C)	SCL (Clause 4.3)
UC1	Disabling/Bypassing Protection Modules (4.4.2)	Moderate	Minimal Security
	Rollback Attacks on Updates (4.4.1)	Low	
	MITM on Backend Links (4.4.3)	Moderate	
UC2	Social Engineering to Disable Protection (4.4.6)	Significant	Medium Security
	MITM on Cloud Connections (4.4.3)	Moderate	
	Evasion Attacks (4.4.5)	Significant	
UC3	Compromised Update Packages (4.4.1)	Significant	High Security
	Privilege Escalation on PwDE Services (4.4.2)	Significant	
	Leakage of Sensitive Data (4.4.3)	Moderate	
UC4	Social Engineering to Disable Protection (4.4.6)	High	High Security
	Trojanized Distribution Channels (4.4.4)	<u>Significant</u>	
	Telemetry/Log Exposure (4.4.3)	<u>Significant</u>	
UC5	Compromised Threat-Intel Feeds (4.4.3)	<u>Significant</u>	Custom SCL based on proposed values in Annex C.5, Medium Security
	Management/API Abuse (4.4.2)	Moderate	
	SBOM Manipulation (4.4.4)	Moderate	
UC6	Malicious SDKs / Privilege Abuse (4.4.4/4.4.5)	High	High Security
	Risky Wi-Fi / MITM to Backend (4.4.3)	<u>Significant</u>	
	Untrusted Application Distributor / Sideload Supply Chain (4.4.4)	<u>Significant</u>	

4.7 Architecture

The clause aims to identify key functional architecture modules that the PwDE discussed in the present document should include. The presented architecture is illustrated in Figure 2 and its modules are:

- **User Interface (UI):** Its purpose is to be the front-end where users interact with the PwDE, allowing users to initiate scans, view alerts, configure settings, manage quarantined files, and check system status. Its key role is to act as the control and monitoring point for the rest of the PwDE system.
- **Signature Database (Signature DB):** Its purpose is to store known malware signatures (i.e. their unique patterns that identify their specific threats), providing data for pattern-matching during scans and enabling quick identification of known malware. Its key role is to be the backbone for signature-based detection, which is fast and reliable for known threats.
- **Heuristics Engine:** Its purpose is to detect suspicious or potentially malicious files by analysing behaviour, structure, or code patterns rather than exact matches by using rules and algorithms to flag unknown or new threats (zero-day detection). Its key role is to complement the Signature DB by finding malware that has not yet been added to the database.
- **Detection Logic:** Its purpose is to manage the decision-making actions that combines inputs from the Signature DB, Heuristics Engine, and Sandbox Engine by evaluating scan results, determining threat levels, and deciding whether to block, quarantine, or allow a file. Its key role is to be the "central brain" for threat assessment.
- **Sandbox Engine:** Its purpose is to safely execute suspicious files in an isolated environment to observe behaviour without harming the host system by monitoring file actions (e.g. network connections, file system changes) to determine if it is malicious. Its key role is to enable dynamic analysis for more accurate detection.
- **Quarantine Management:** Its purpose is to safely isolate detected threats to prevent them from executing or spreading, allowing users to restore, delete, or submit files for further analysis. Its key role is to minimize risk while preserving files for investigation.
- **Update System:** Its purpose is to keep the PwDE up to date by fetching new malware signatures, heuristics rules, and software patches. Its key role is to ensure ongoing protection against evolving threats.
- **Logging & Telemetry:** Its purpose is to record activity, detections, and actions taken by the PwDE, to support incident analysis, compliance, and product improvement. Moreover, it may send anonymized data to the PwDE manufacturer for threat intelligence. Its key role is to facilitate auditability and continuous improvement.
- **Secure Cloud Backend:** Its purpose is to guarantee access towards remote infrastructure supporting advanced detection and updates, allowing to provide cloud-based threat analysis, to store large threat intelligence datasets, to enable cross-device syncing, and assists in large-scale pattern recognition. Its key role is to extend protection beyond the local device, enabling **cloud**-assisted security.

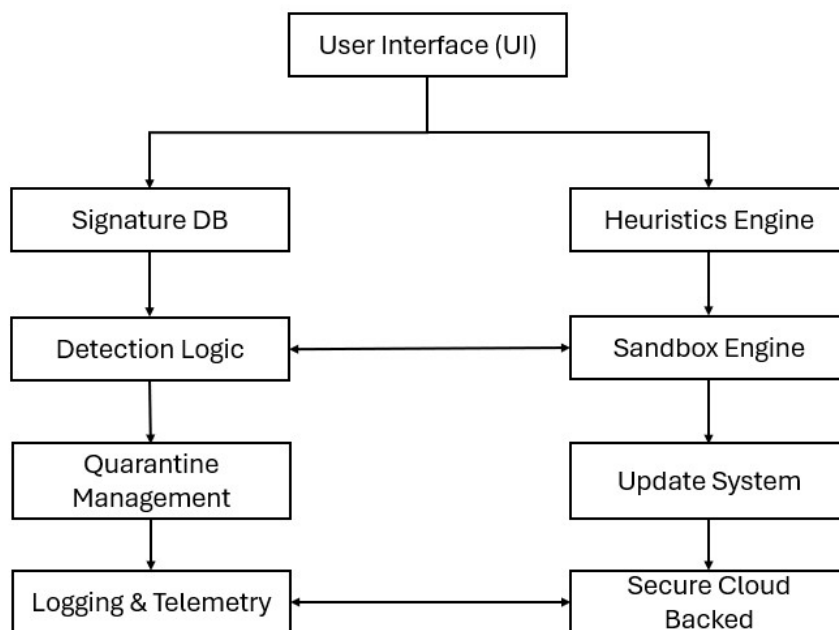


Figure 2: Generic functional antivirus/anti-malware architecture

4.8 Operational Environment

4.8.1 Logical Operational Environment:

While an antivirus/anti-malware product may work as standalone product, it may also interact with other possible cybersecurity PwDE. What it is sure is dependency on an underlying OS. To this end, it is key to know the wide range of OS in the market and their characteristics (i.e. performance, security, etc.) for a proper PwDE development and placement in the market. To this end, antivirus/anti-malware manufacturers should know the requirements, risks and others possible aspects on the OS category (Ref to OS WI). Moreover, for transparency reasons when placing an antivirus/anti-malware product in the market, the vendor should identify and notify in a clear way the supported OS types and the minimum version of them.

4.8.2 Physical Operational Environment:

The manufacturer of the product should provide the end-user with the following information:

User Devices: If the PwDE may be deployed on laptops/desktops and/or virtual desktops.

Hardware Specifications: The physical requirements that the PwDE needs to properly perform within an OS, giving the minimum amount of RAM (GB), which kinds and version of processors, and the storage amount required in the disk space (MB/GB).

Environmental Conditions: The hardware where the PwDE is installed may need/require temperature-controlled environments (e.g. 15 - 30 °C). The PwDE vendor should notify this information with the environmental conditions in which the PwDE was tested to properly perform.

Power Supply: Electrical plug-ins and power supply voltages are different across the multiple market regions/nations, the PwDE vendor should identify the needs of each market where it aims to be present and adapt its PwDE to the market.

4.8.3 Chain of Trust

An important element in terms of placing the PwDE (clause 4.1) into the market are trust-related aspects to be considered in the context of a chain of trust. These aspects may ensure that the PwDE can be trusted by the market and

that it comes from a trustworthy source with the objective of protecting users from threats and maintain system integrity. The aspects considered are:

- **Certification and Compliance with Trusted Standards:** Following what legal and technical standards [i.1], [i.2], [i.3] define ensures that the PwDE meets certain security and privacy requirements, in addition if the PwDE is certified by a trusted authority, this action acts as a seal of approval that enhances trustworthiness.
- **Root of Trust for Updates:** Any update of the PwDE or the data it uses to perform its functionalities should be signed by a trusted Certificate Authority (CA) to ensure that they have not been tampered with during transmission and verified as originating from a legitimate source and have not been altered or corrupted in transit by using cryptographic signatures.
- **Transparency and Provenance of the PwDE:** Transparent disclosure of the PwDE's source code can help in building trust within the security community. Moreover, users should have access to detailed provenance information about the PwDE, such as the development process, supply chain, and any third-party components used. This helps ensure that the software has been created and maintained with trustworthiness in mind. To improve transparency on the development processes, a source code-based audit should be included, especially in case of closed source. This audit may include code-based source code assessments like automated vulnerability scans, static analysis, etc. The generated reports should be made available in machine and human readable formats allowing the user to act properly in case a vulnerability is found in a third-party component after the release of the product.
- **End-to-End Integrity Assurance:** It is key to the use of verification mechanisms for the integrity of files, updates, and components. This is often done using cryptographic hashes, ensuring that no modifications or tampering has occurred at any point in the software lifecycle. Furthermore, all communications between the PwDE and external sources (e.g. cloud-based threat intelligence or update servers) would benefit from using encryption technologies based on industry-standard protocols, ensuring that the data is protected during transit.
- **User Privacy and Data Protection:** Regarding the relationship between the PwDE and the end users, the first one should comply with privacy regulations such as the GDPR in the EU, or other local data protection laws when GDPR does not overlap it. In addition, trust is built when users feel their personal data is not being misused or over-collected and that any data collected or processed is securely encrypted, both in transit and at rest, to prevent unauthorized access.
- **Reputation and Accountability:** Trust can be enhanced if the PwDE vendor has a history of responsible disclosure of vulnerabilities, prompt security patches, and user support. Moreover, PwDE vendors should have a clear and transparent incident response process in place for handling security incidents or breaches with clear and easy notification procedures towards the end-user.
- **Non-repudiation and Auditing:** The PwDE shall record all actions taken in a log all actions taken (e.g. quarantining, deleting files, generating alerts) in a manner that ensures they cannot be denied or tampered later and that can be understood by end-users with a minimum technical knowledge. Furthermore, an audit trail should be maintained for all critical events, such as detected threats, user actions, and updates, which can be reviewed to ensure the software is functioning as intended. These aspects help in providing transparency and allowing the end-user to understand what is happening in the system, triggering an increment of trustworthiness on the PwDE.
- **Chain of Trust for Threat Intelligence:** The PwDE shall rely on reputable and trusted threat intelligence manufacturers to help identify new threats, and even with these trusted sources, it should verify the authenticity of threat intelligence data before acting on it. This ensures that actions such as blocking, quarantining, or removing files are based on reliable and accurate information.
- **Collaboration with Third Parties:** The PwDE in the present document may work as standalone solution for its specific functionality but it should facilitate secure collaboration with other security tools and platforms (e.g. cloud-based threat intelligence feeds, firewalls, etc.). Proper API security and mutual trust between these systems are necessary to build a cohesive security ecosystem. Moreover, another aspect in terms of third parties collaboration is the maintenance of cross-platform trust, ensuring consistent behaviour, protection, and updates regardless of the underlying OS.
- **Regulatory and Legal Trust Requirements:** Furthermore, the PwDE vendors shall provide mechanisms for users to report issues or security breaches, and offering customer support to resolve disputes or concerns.

4.9 Users

4.9.0 Introduction

Within the market, different types of users coexist, each with its own skills and knowledge level. Together with the security levels described in clause 4.3, the PwDE manufacturers can design product features, documentation, and support accordingly. To this end, the proposed users for the PwDE in the present document are described in the following clauses:

4.9.1 Common Users (Personal Desktops)

Individuals using computers for personal work, browsing, entertainment, online banking, and shopping. This kind of user is often non-technical, and security is not its primary focus. The expected skills are:

- **Basic device operation:** Knows how to install and update software when guided.
- **Basic security awareness:** Recognizes obvious suspicious links or email attachments but may still click by accident.
- **Simple maintenance habits:** Can run a scan when prompted; may understand "quarantine" as "safe storage for suspicious files."
- **Password hygiene:** Basic knowledge of strong passwords but often reuses them.
- **Update awareness:** Accepts updates when prompted but may not be proactively checked.

Possible design aspects that PwDE manufacturers may take into consideration are the use of simple UI with clear "Safe / At Risk" indicators, automated updates and scanning, one-click remediation with minimal technical terms and lightweight system impact.

4.9.2 Enterprises (Private Data)

The profiles for this user are businesses of varying sizes with proprietary data (IP, customer data, trade secrets) that usually have IT staff and defined security policies. The expected skills are:

- **IT and security team proficiency:** Able to configure policies, deploy the PwDE centrally, and integrate with EDR/XDR or SIEM.
- **Incident handling:** Knows how to investigate and contain a malware outbreak using the PwDE logs and management console.
- **Compliance awareness:** Understands legal requirements for data protection (e.g. GDPR, HIPAA).
- **Network segmentation knowledge:** Knows how to apply the PwDE protection in different network zones (servers, endpoints).
- **Update control:** Able to manage the PwDE updates in a controlled environment (e.g. testing before mass rollout).

Possible design aspects that PwDE manufacturers may take into consideration are centralized management console for policy enforcement, integration with enterprise security stack, detailed logging and reporting, role-based access control for admins and options for offline or air-gapped updates.

4.9.3 Public Administration (Private Data Used for Public Purposes)

The profiles for this user are government agencies, municipal bodies, healthcare entities, public education systems that handle sensitive citizen data, often subject to strict legal oversight, and may be targeted by state-sponsored actors. The expected skills are:

- **High compliance literacy:** Deep familiarity with public-sector regulations, retention policies, and audit requirements.

- **Secure process adherence:** Ability to follow strict incident reporting and escalation procedures.
- **Data classification awareness:** Knows how to apply different security levels to public, restricted, and confidential data.
- **Cross-agency coordination:** Skills to handle malware incidents affecting multiple departments.
- **Awareness of targeted threats:** Knowledge of phishing, social engineering, and advanced persistent threats (APTs) targeting public infrastructure.

Possible design aspects that PwDE manufacturers may take into consideration are strong compliance and audit trail features, multi-tenancy support for different agencies/departments, integration with government-certified security tools, policy templates aligned with national cybersecurity frameworks and advanced threat detection (including zero-day and APT indicators).

5 Requirements specifications

5.1 Introduction

The technical requirements of the present document apply under the environmental profile for operation of the equipment, which should be in accordance with its intended use. The equipment should comply with the technical requirements of the present document at all times when operating within the boundary limits of the operational environmental profile defined by its intended use.

5.2 Security Requirements

5.2.1 General

The following clauses present the identified and defined security requirements for the PwDE in the present document. The security requirements are grouped based the essential cybersecurity requirements defined in the CRA Annex I [i.1]. All these requirements may have different applicability depending on the SCL the PwDE aims to achieve and/or the UC it is intended for. To this end, each of the identified security requirements in this Clause are mapped to the previous UCs (clause 4.5.1) and the SCLs (clause 4.3) to determine the corresponding requirements applicability.

Product's technical requirements specifications

This clause will provide technical specifications for the product in the form of requirements.

5.2.2 Known Exploitable Vulnerabilities

- **REQ-KEV-01:** The PwDE shall include a vulnerability management process that enables timely identification, remediation, and disclosure of vulnerabilities.
- **REQ-KEV-02:** The PwDE shall include a basic process for identifying and remediating critical vulnerabilities within defined timeframes based on the severity of the vulnerability.
- **REQ-KEV-03:** The PwDE shall include regular security testing to identify possible known and non-solved vulnerabilities.
- **REQ-KEV-04:** The PwDE shall include a continuous vulnerability assessment of infrastructure and applications and apply regular third-party penetration testing.
- **REQ-KEV-05:** The PwDE shall include rapid emergency response for exploited vulnerabilities.

5.2.2.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High

REQ-KEV-01										
REQ-KEV-02										
REQ-KEV-03										
REQ-KEV-04										
REQ-KEV-05										

Note: As stated in Clause 4.3, SCLS are inclusive: Medium includes Minimal, High includes Medium.

5.2.3 Secure by Default Configuration

- **REQ-SDC-01:** The PwDE shall include mechanisms to detect and recover from corruption of core components.
- **REQ-SDC-02:** The PwDE shall follow the security-by-default principle and be shipped with security-hardened default settings, activate minimal security functions including automatic updates and active real-time protection.
- **REQ-SDC-03:** Remote management interfaces shall be disabled by default and require explicit user activation with strong authentication.
- **REQ-SDC-04:** The PwDE shall detect virus employing signature-based techniques with the possibility to offer more complex and complete technologies.
- **REQ-SDC-05:** The PwDE shall detect malware employing evasion techniques, including code obfuscation, fileless malware, and polymorphic malware.
- **REQ-SDC-06:** The PwDE shall include proactive detection mechanisms, such as behavioural analysis and sandboxing.
- **REQ-SDC-07:** The PwDE shall make use of secure communications either between internal system components and/or external systems.
- **REQ-SDC-08:** The PwDE shall not modify, affect or change the characteristics and security requirements of the operating system hosting it.

5.2.3.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-SDC-01										
REQ-SDC-02										
REQ-SDC-03										
REQ-SDC-04										
REQ-SDC-05										
REQ-SDC-06										
REQ-SDC-07										
REQ-SDC-08										

Note: As stated in Clause 4.3, SCLS are inclusive: Medium includes Minimal, High includes Medium.

5.2.4 Security Updates

- **REQ-SU-01:** The PwDE shall ensure that its data sources are verifiable and include publicly available threat reports and/or trusted private sources.
- **REQ-SU-02:** The PwDE shall offer external access allowed only to the PwDE vendor update domains.
- **REQ-SU-03:** The PwDE shall use vendor signed updates when updating its core subsystem or the databases data in the PwDE.
- **REQ-SU-04:** The PwDE shall make use of authenticated and encrypted communications between itself and the PwDE vendor domains.

- **REQ-SU-05:** The PwDE shall allow the user to be able to manage the update (when available) signatures DB and scanning actions manually when desired.
- **REQ-SU-06:** The PwDE vendor shall offer regular, cryptographically verified security updates for a defined minimum period.

5.2.4.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-SU-01										
REQ-SU-02										
REQ-SU-03										
REQ-SU-04										
REQ-SU-05										
REQ-SU-06										

5.2.5 Authentication and Access Control

- **REQ-AAC-01:** The PwDE shall prevent unauthorized deactivation, bypassing, or tampering by local or remote actors.
- **REQ-AAC-02:** The PwDE shall prevent unauthorized access to detection logic, heuristic algorithms, and machine learning models.
- **REQ-AAC-03:** The PwDE UI shall not grant system admin rights and call only backend APIs to avoid.
- **REQ-AAC-04:** The PwDE shall apply read-only actions for detection and write-only actions for updating the system when affecting its signatures and/or heuristics models DB components.
- **REQ-AAC-05:** The PwDE shall grant that its quarantine component writes and deletes data only inside the quarantine directory.
- **REQ-AAC-06:** The PwDE shall offer local management interfaces with strong authentication and remote management shall be disabled by default.
- **REQ-AAC-07:** The PwDE shall support multi-factor authentication for administrative access and strict least privilege enforcement.
- **REQ-AAC-08:** The PwDE shall include role-based access control with granular permissions with mandatory multi-factor authentication for all privileged access and prevent unauthorized access to detection logic and ML models within the PwDE subsystems.

5.2.5.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-AAC-01										
REQ-AAC-02										
REQ-AAC-03										
REQ-AAC-04										
REQ-AAC-05										
REQ-AAC-06										
REQ-AAC-07										
REQ-AAC-08										

5.2.6 Confidentiality Protection

- **REQ-CON-01:** The PwDE shall securely and automatically update antivirus signature databases and detection engines to prevent man-in-the-middle or rollback attacks.
- **REQ-CON-02:** The PwDE shall encrypt stored detection, mitigation and quarantine-related data at rest.
- **REQ-CON-03:** The PwDE shall use a trusted method of distributing updates and signatures.
- **REQ-CON-04:** The PwDE shall outline how user data is collected, stored, and processed.
- **REQ-CON-05:** The PwDE shall present transparent privacy measures to the user, ensuring that data is not unnecessarily shared with third parties.

5.2.6.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-CON-01										
REQ-CON-02										
REQ-CON-03										
REQ-CON-04										
REQ-CON-05										

5.2.7 Integrity Protection

- **REQ-INT-01:** The PwDE shall include mechanisms to ensure that files, updates, and components are authenticated and integrity-verified using digital signatures.
- **REQ-INT-02:** The PwDE shall ensure that all telemetry data, logs, and threat reports are transmitted via secure, encrypted channels.
- **REQ-INT-03:** The PwDE shall maintain tamper-resistant logs of detections, updates, configuration changes, and access to quarantined files.
- **REQ-INT-04:** All PwDE updates, including virus definition files and patches, shall be cryptographically signed by the software vendor using a private key.
- **REQ-INT-05:** The PwDE shall offer secure integration with external threat intelligence feeds for advance detection.

5.2.7.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-INT-01										
REQ-INT-02										
REQ-INT-03										
REQ-INT-04										

5.2.8 Data Minimization

- **REQ-DM-01:** The PwDE shall comply with applicable data protection regulations, including GDPR, ensuring no unnecessary PII is collected or transmitted without user consent.
- **REQ-DM-02:** The PwDE shall collect only the necessary data to operate effectively.

- **REQ-DM-03:** The PwDE shall follow a "Privacy by Design" approach including elements such as conduct formal PIAs on data collected, provide public-facing privacy datasheets/reports that clearly explain the data management (what data is collected, why it is necessary, and how it is used).
- **REQ-DM-04:** The PwDE shall ensure that any data processing for "purpose independent of the instructions of the cloud service customer" (e.g., for marketing or advertising) requires explicit consent and is not a condition for receiving the service.

5.2.8.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-DM-01										
REQ-DM-02										
REQ-DM-03										
REQ-DM-04										

5.2.9 Availability Protection

- **REQ-AP-01:** The PwDE shall maintain minimum viable protection levels during degraded operational conditions, such as partial system failure or incomplete updates.
- **REQ-AP-02:** The PwDE shall include redundancy mechanisms for critical components in case of partial system failure.

5.2.9.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-AP-01										
REQ-AP-02										

5.2.10 Impact minimization

- **REQ-MIN-01:** The PwDE include robust resistance to privilege escalation attacks that could disable protection modules.
- **REQ-MIN-02:** The PwDE shall include rollback mechanisms for failed updates.

5.2.10.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-MIN-01	X	X	X	X	X	X	X	X		
REQ-MIN-02										

5.2.11 Secure by Design

- **REQ-SBDLAS-01:** The PwDE shall implement self-protection mechanisms to prevent malicious software from disabling or altering core services.
- **REQ-SBD-02:** The PwDE shall follow the secure-by-design principle looking at known architectural and functional vulnerabilities.
- **REQ-SDB-03:** The PwDE shall follow the PoLP to ensure the minimum level of access necessary to perform its required tasks.

- **REQ-SBD-04:** The PwDE shall detail enough provenance data to increase the trust from the users.
- **REQ-SBD-05:** The PwDE shall not add difficulties on the integration of the current PwDE and other possible cybersecurity PwDE such as firewalls or network security solutions, and the underlying OS.
- **REQ-SBD-06:** The PwDE shall have a sandbox engine component which runs isolated, without any outbound network by default and ephemeral storage.
- **REQ-SBD-07:** The PwDE shall deliver deep scanning capabilities of all file types and encrypted traffic, aggressive heuristic and behavioral analysis and sandboxing suspicious files before execution.

5.2.11.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-SBD-01										
REQ-SBD-02										
REQ-SBD-03										
REQ-SBD-04										
REQ-SBD-05										
REQ-SBD-06										
REQ-SDB-07										X

5.2.12 Exploitation Mitigation Mechanisms and Techniques

- **REQ-EMM-01:** The PwDE vendor shall build trust in the developed PwDE by disclosing, when possible, the identified incidents and steps taken to mitigate them to the user.
- **REQ-EMM-02:** The PwDE shall provide clear user guidance and tools that foster a better security posture such as user-friendly dashboards and alerts that translate technical security information into actionable steps for the user.

5.2.12.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-EMM-01										
REQ-EMM-02										

5.2.13 Logging and Monitoring Mechanisms

- **REQ-LOG-01:** The PwDE shall generate, store and present comprehensive logs for detections, updates, configuration changes and quarantined files access for users to understand them without prior technical experience.
- **REQ-LOG-02:** The PwDE shall offer the users the ability to review and manage quarantined files with proper warnings and guidance.
- **REQ-LOG-03:** The PwDE shall ensure that all logs are securely stored, tamper-resistant and optionally exportable to centralized security management systems (e.g., SIEM).
- **REQ-LOG-04:** The PwDE shall generate and manage SBOMs with the updated data.
- **REQ-LOG-05:** The PwDE shall ensure accountability and provide a record of action logs that users may need in case of disputes or forensic investigations.
- **REQ-LOG-06:** The PwDE shall append the metrics and data generated in its logging files and allow access to them, only to authorized endpoints.

- **REQ-LOG-07:** The PwDE shall include real-time logging of critical events with automatic alerting to Security Operations Center.

5.2.13.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-LOG-01										
REQ-LOG-02										
REQ-LOG-03										
REQ-LOG-04										
REQ-LOG-05										
REQ-LOG-06										
REQ-LOG-07										

5.2.14 Data Removal and Transference Mechanisms

- **REQ-DRT-01:** The PwDE shall provide a fallback behaviour mechanism if update procedures fail.

5.2.14.1 Mapping of Requirements Applicability to the UCs and SCLs

Requirements	UCs							SCLs		
	UC1	UC2	UC3	UC4	UC5	UC6	UC7	Minimal	Medium	High
REQ-DRT-01										

5.3 Vulnerability Handling Requirements

5.3.1 General

5.3.2 Product Dependencies

5.3.3 Vulnerabilities Remediation

5.3.4 Effective and Regular Testing

5.3.5 Security Updates Availability

5.3.6 Vulnerability Disclosure Policies

5.3.7 Information Sharing

5.3.8 Securely Update Distribution Mechanisms

5.3.9 Security Updates Dissemination

6 Assessing for compliance with requirements

This clause will define an assessment criterion for each of the requirements specified above. One to one, the idea is to define what is necessary to validate the requirements is achieved which mitigation are needed to accomplish it and protect the PwDE from a threat. The current structure is a proposal, WIP.

6.1 General

This clause is crucial towards the final decision on whether a PwDE accomplishes the security requirements based on the UC and/or the SCL it may belong towards its placement in the EU market. For each security requirements defined in Clause 5, the following clauses apply an assessment criterion to identify how a requirement is properly achieved.

The proposed assessment methodology follows the following general principles:

- **Verifiable Evidence:** For each requirement, clearly specify the type(s) of evidence required for conformity (e.g. documented policy, procedure, architectural design, configuration baseline, audit log, scan report, penetration test report, third-party certification, code review results, test reports).
- **Methodology:** Employ a combination of document review, interviews, observation of deployed systems, and technical testing (e.g. vulnerability scans, penetration tests, functional security testing).
- **Frequency:** Define the frequency of internal assessments and external audits (e.g. annual for policies/high-level controls, continuous/monthly for technical controls).
- **Traceability:** Ensure clear traceability from the requirement to the implemented control and its verification.

6.2 Security Requirements Assessment

6.2.1 Known Exploitable Vulnerabilities

REQ-KEV-01

- **Requirement Description:** The PwDE shall include a vulnerability management process that enables timely identification, remediation, and disclosure of vulnerabilities.
- **Evidence:**
 - Documented vulnerability management policy/procedure;
 - recent vulnerability scan reports (internal/external);
 - penetration test reports; remediation tracking system (e.g. Jira tickets) showing adherence to SLAs;
 - public security advisories (if applicable).
- **Acceptance Criteria:**
 - Zero critical/high-risk vulnerabilities remaining unmitigated beyond defined SLAs;
 - evidence of regular review of threat intelligence feeds
 - clear process for disclosure.

REQ-KEV-02

- **Requirement Description:** The PwDE shall include a basic process for identifying and remediating critical vulnerabilities within defined timeframes based on the severity of the vulnerability.
- **Evidence:**
- **Acceptance Criteria:**

REQ-KEV-03

- **Requirement Description:** The PwDE shall include regular security testing to identify possible known and non-solved vulnerabilities.
- **Evidence:**
- **Acceptance Criteria:**

REQ-KEV-04

- **Requirement Description:** The PwDE shall include a continuous vulnerability assessment of infrastructure and applications and apply regular third-party penetration testing.
- **Evidence:**
- **Acceptance Criteria:**

REQ-KEV-05

- **Requirement Description:** The PwDE shall include rapid emergency response for exploited vulnerabilities.
- **Evidence:**
- **Acceptance Criteria:**

6.2.2 Secure by Default Configuration

REQ-SDC-01

- **Requirement Description:** The PwDE shall include mechanisms to detect and recover from corruption of core components.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SDC-02

- **Requirement Description:** The PwDE shall follow the security-by-default principle and be shipped with security-hardened default settings, activate minimal security functions including automatic updates and active real-time protection.
- **Evidence:** Product installation guide; default configuration manifest; automated test scripts verifying default settings; user documentation.
- **Acceptance Criteria:** Verification that automatic updates and real-time protection are enabled by default, that attack surface is minimized by default settings.

REQ-SDC-03

- **Requirement Description:** Remote management interfaces shall be disabled by default and require explicit user activation with strong authentication.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SDC-04:

- **Requirement Description:** The PwDE shall detect virus employing signature-based techniques with the possibility to offer more complex and complete technologies.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SDC-05:

- **Requirement Description:** The PwDE shall detect malware employing evasion techniques, including code obfuscation, fileless malware, and polymorphic malware.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SDC-06:

- **Requirement Description:** The PwDE shall include proactive detection mechanisms, such as behavioural analysis and sandboxing.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SDC-07:

- **Requirement Description:** The PwDE shall make use of secure communications either between internal system components and/or external systems.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SDC-08:

- **Requirement Description:** The PwDE shall not modify, affect or change the characteristics and security requirements of the operating system hosting it.
- **Evidence:**
- **Acceptance Criteria:**

6.2.3 Security Updates

REQ-SU-04

- **Requirement Description:** The PwDE shall ensure that its data sources are verifiable and include publicly available threat reports and/or trusted private sources.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SU-02

- **Requirement Description:** The PwDE shall offer external access allowed only to the PwDE vendor update domains.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SU-03

- **Requirement Description:** The PwDE shall use vendor signed updates when updating its core subsystem or the databases data in the PwDE.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SU-04

- **Requirement Description:** The PwDE shall make use of authenticated and encrypted communications between itself and the PwDE vendor domains.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SU-05

- **Requirement Description:** The PwDE shall allow the user to be able to manage the update (when available) signatures DB and scanning actions manually when desired.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SU-06

- **Requirement Description:** The PwDE shall allow the user to be able to manage the update (when available) signatures DB and scanning actions manually when desired.
- **Evidence:**
- **Acceptance Criteria:**

6.2.4 Authentication and Access Control

REQ-AAC-01

- **Requirement Description:** The PwDE shall prevent unauthorized deactivation, bypassing, or tampering by local or remote actors.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AAC-02

- **Requirement Description:** The PwDE shall prevent unauthorized access to detection logic, heuristic algorithms, and machine learning models.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AAC-03

- **Requirement Description:** The PwDE UI shall not grant system admin rights and call only backend APIs to avoid.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AAC-04

- **Requirement Description:** The PwDE shall apply read-only actions for detection and write-only actions for updating the system when affecting its signatures and/or heuristics models DB components.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AAC-05

- **Requirement Description:** The PwDE shall grant that its quarantine component writes and deletes data only inside the quarantine directory.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AAC-06

- **Requirement Description:** The PwDE shall offer local management interfaces with strong authentication and remote management shall be disabled by default.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AAC-07

- **Requirement Description:** The PwDE shall support multi-factor authentication for administrative access and strict least privilege enforcement.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AAC-08

- **Requirement Description:** The PwDE shall include role-based access control with granular permissions with mandatory multi-factor authentication for all privileged access and prevent unauthorized access to detection logic and ML models within the PwDE subsystems.
- **Evidence:**
- **Acceptance Criteria:**

6.2.5 Confidentiality Protection

REQ-CON-01

- **Requirement Description:** The PwDE shall securely and automatically update antivirus signature databases and detection engines to prevent man-in-the-middle or rollback attacks.
- **Evidence:**
- **Acceptance Criteria:**

REQ-CON-02

- **Requirement Description:** The PwDE shall encrypt stored detection, mitigation and quarantine-related data at rest.
- **Evidence:**
- **Acceptance Criteria:**

REQ-CON-03

- **Requirement Description:** The PwDE shall use a trusted method of distributing updates and signatures.
- **Evidence:**
- **Acceptance Criteria:**

REQ-CON-04

- **Requirement Description:** The PwDE shall outline how user data is collected, stored, and processed.

- **Evidence:**
- **Acceptance Criteria:**

REQ-CON-05

- **Requirement Description:** The PwDE shall present transparent privacy measures to the user, ensuring that data is not unnecessarily shared with third parties.
- **Evidence:**
- **Acceptance Criteria:**

6.2.6 Integrity Protection

REQ-INT-01

- **Requirement Description:** The PwDE shall include mechanisms to ensure that files, updates, and components are authenticated and integrity-verified using digital signatures.
- **Evidence:** Update mechanism design document; cryptographic key management procedures; sample update package with digital signature; client-side update verification logs; rollback mechanism test reports.
- **Acceptance Criteria:** Evidence of digital signature verification prior to update installation; use of standard cryptographic algorithms; functional rollback capability.

REQ-INT-02

- **Requirement Description:** The PwDE shall ensure that all telemetry data, logs, and threat reports are transmitted via secure, encrypted channels.
- **Evidence:**
- **Acceptance Criteria:**

REQ-INT-3

- **Requirement Description:** The PwDE shall maintain tamper-resistant logs of detections, updates, configuration changes, and access to quarantined files.
- **Evidence:**
- **Acceptance Criteria:**

REQ-INT-4

- **Requirement Description:** All PwDE updates, including virus definition files and patches, shall be cryptographically signed by the software vendor using a private key.
- **Evidence:**
- **Acceptance Criteria:**

REQ-INT-05

- **Requirement Description:** The PwDE shall offer secure integration with external threat intelligence feeds for advance detection.
- **Evidence:**

- **Acceptance Criteria:**

6.2.7 Data Minimization

REQ-DM-01

- **Requirement Description:** The PwDE shall comply with applicable data protection regulations, including GDPR, ensuring no unnecessary PII is collected or transmitted without user consent.
- **Evidence:**
- **Acceptance Criteria:**

REQ-DM-02

- **Requirement Description:** The PwDE shall collect only the necessary data to operate effectively.
- **Evidence:**
- **Acceptance Criteria:**

REQ-DM-03

- **Requirement Description:** The PwDE shall follow a "Privacy by Design" approach including elements such as conduct formal PIAs on data collected, provide public-facing privacy datasheets/reports that clearly explain the data management (what data is collected, why it is necessary, and how it is used).
- **Evidence:**
- **Acceptance Criteria:**

REQ-DM-04

- **Requirement Description:** The PwDE shall ensure that any data processing for "purpose independent of the instructions of the cloud service customer" (e.g., for marketing or advertising) requires explicit consent and is not a condition for receiving the service.
- **Evidence:**
- **Acceptance Criteria:**

6.2.8 Availability Protection

REQ-AP-01

- **Requirement Description:** The PwDE shall maintain minimum viable protection levels during degraded operational conditions, such as partial system failure or incomplete updates.
- **Evidence:**
- **Acceptance Criteria:**

REQ-AP-02

- **Requirement Description:** The PwDE shall include redundancy mechanisms for critical components in case of partial system failure.
- **Evidence:**
- **Acceptance Criteria:**

6.2.9 Impact minimization

REQ-MIN-01

- **Requirement Description:** The PwDE include robust resistance to privilege escalation attacks that could disable protection modules.
- **Evidence:**
- **Acceptance Criteria:**

REQ-MIN-02

- **Requirement Description:** The PwDE shall include rollback mechanisms for failed updates.
- **Evidence:**
- **Acceptance Criteria:**

6.2.10 Secure by Design

REQ-SBDLAS-01

- **Requirement Description:** The PwDE shall implement self-protection mechanisms to prevent malicious software from disabling or altering core services.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SBD-02

- **Requirement Description:** The PwDE shall follow the secure-by-design principle looking at known architectural and functional vulnerabilities.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SDB-03

- **Requirement Description:** The PwDE shall follow the PoLP to ensure the minimum level of access necessary to perform its required tasks.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SBD-04

- **Requirement Description:** The PwDE shall detail enough provenance data to increase the trust from the users.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SBD-05

- **Requirement Description:** The PwDE shall not add difficulties on the integration of the current PwDE and other possible cybersecurity PwDE such as firewalls or network security solutions, and the underlying OS.
- **Evidence:**
- **Acceptance Criteria:**

REQ-SBD-06

- **Requirement Description:** The PwDE shall have a sandbox engine component which runs isolated, without any outbound network by default and ephemeral storage.

- **Evidence:**
- **Acceptance Criteria:**

REQ-SBD-07

- **Requirement Description:** The PwDE shall deliver deep scanning capabilities of all file types and encrypted traffic, aggressive heuristic and behavioral analysis and sandboxing suspicious files before execution.
- **Evidence:**
- **Acceptance Criteria:**

6.2.11 Exploitation Mitigation Mechanisms and Techniques

REQ-EMM-01

- **Requirement Description:** The PwDE vendor shall build trust in the developed PwDE by disclosing, when possible, the identified incidents and steps taken to mitigate them to the user.
- **Evidence:**
- **Acceptance Criteria:**

REQ-EMM-02

- **Requirement Description:** The PwDE shall provide clear user guidance and tools that foster a better security posture such as user-friendly dashboards and alerts that translate technical security information into actionable steps for the user.
- **Evidence:**
- **Acceptance Criteria:**

6.2.12 Logging and Monitoring Mechanisms

REQ-LOG-01

- **Requirement Description:** The PwDE shall generate, store and present comprehensive logs for detections, updates, configuration changes and quarantined files access for users to understand them without prior technical experience.
- **Evidence:**
- **Acceptance Criteria:**

REQ-LOG-02

- **Requirement Description:** The PwDE shall offer the users the ability to review and manage quarantined files with proper warnings and guidance.
- **Evidence:**
- **Acceptance Criteria:**

REQ-LOG-03

- **Requirement Description:** The PwDE shall ensure that all logs are securely stored, tamper-resistant and optionally exportable to centralized security management systems (e.g., SIEM).
- **Evidence:** Automated SBOM generation tools/processes; sample SBOMs (e.g. SPDX, CycloneDX format); procedures for updating SBOMs with component changes.

- **Acceptance Criteria:** Comprehensive and accurate SBOMs for all delivered software components, including open-source and third-party libraries; mechanism for making SBOMs available to relevant parties.

REQ-LOG-04

- **Requirement Description:** The PwDE shall generate and manage SBOMs with the updated data.
- **Evidence:**
- **Acceptance Criteria:**

REQ-LOG-05

- **Requirement Description:** The PwDE shall ensure accountability and provide a record of action logs that users may need in case of disputes or forensic investigations.
- **Evidence:**
- **Acceptance Criteria:**

REQ-LOG-06

- **Requirement Description:** The PwDE shall append the metrics and data generated in its logging files and allow access to them, only to authorized endpoints.
- **Evidence:**
- **Acceptance Criteria:**

REQ-LOG-07

- **Requirement Description:** The PwDE shall include real-time logging of critical events with automatic alerting to Security Operations Center.
- **Evidence:**
- **Acceptance Criteria:**

6.2.13 Data Removal and Transference Mechanisms

REQ-DRT-01

- **Requirement Description:** The PwDE shall provide a fallback behaviour mechanism if update procedures fail.
- **Evidence:**
- **Acceptance Criteria:**

Annex A (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

This informative annex is intended to provide the relevant information on the covered/not covered cybersecurity risks based on the assessment of cybersecurity risks performed during the standard's development.

The present document has been prepared under the Commission's standardisation request C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 [i.1] known as the Cyber Resilience Act (CRA).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Table A.1: Relationship between the present document and the requirements of Regulation 2024/2847

Harmonised Standard ETSI EN 304 619					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
1					
2					
3					
...					

Key to columns:

Requirement:

No A unique identifier for one row of the table which may be used to identify a requirement.

Description A textual reference to the requirement.

Requirements of Regulation

Identification of article(s) defining the requirement in the Regulation.

Clause(s) of the present document

Identification of clause(s) defining the requirement in the present document unless another document is referenced explicitly.

Requirement Conditionality:

U/C Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the manufacturer's claimed functionality of the equipment (C).

Condition Explains the conditions when the requirement is or is not applicable for a requirement which is classified "conditional".

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Information on the methodology for the assessment of cybersecurity risks used to develop the present document

NOTE: This informative annex is intended to provide information on the methodology for the assessment of cybersecurity risks used to develop the present document.

This annex describes the risk assessment methodology applied during drafting of the present document and provides a repeatable approach that manufacturers may adopt to determine cybersecurity risks for antivirus/antimalware software PwDE. This methodology determines the residual cybersecurity risk of the PwDE by combining qualitative judgments with numerical scoring on two axes (i.e., Likelihood (L) and Magnitude (M)) and then mapping results to SCLs for proportionate requirements application.

This semi-quantitative approach meets the conditions established in the draft:

- it uses likelihood and magnitude;
- supports qualitative matrices and numeric scoring;
- allows alternative analysis techniques (e.g., fault trees) upstream of L/M;
- and keeps results consistent with the use-case and SCL mapping.

B.1 Principles and references

The approach is consistent with widely used risk management practices (e.g. ISO/IEC 27005 and NIST SP 800-30), adapted to the specific scope and terminology of the present document.

- It distinguishes inherent and residual risk;
- It evaluates likelihood and magnitude using calibrated qualitative scales mapped to numeric values;
- It considers the draft's **threat catalogue** (Clause 4.4), **RFs** (Clause 4.5), **UCs** (Clause 4.6), and **SCLs** (Clause 4.3);
- It supports traceability into Annex A mapping to CRA essential requirements.

B.2 Risk model

The proposed risk model defines the objects of assessment and their relationships (i.e., context) to compute the risk estimation. It establishes a coherent scope and trust boundaries prior to likelihood and impact determination. To apply the presented methodology, the risk model is based on the following elements:

- **Object of assessment:** The elements of value that the PwDE relies on to operate safely. An "asset" is anything whose compromise (confidentiality, integrity, availability, or lawful use) could lead to loss or disruption for the user, the operator, or the ecosystem. Based on this, in this methodology the PwDE architectural components in **Clause 4.7** were considered (i.e. signature/heuristic engines, update/signature pipeline, quarantine store, telemetry/logs, etc.), together with the operational context (Clause 4.8) and the type of users (Clause 4.9).
- **Threats and RFs:** As listed in **Clause 4.4** and Clause 4.5.
- **Controls:** Requirements listed in **Clause 5**.
- **Contexts:** Select the applicable UC among the UCs in Clause 4.6 and the intended SCL target within the SCLs in **Clause 4.3**.

B.3 Identify Threats and RFs

Use the draft's threat families as the baseline list (i.e., update/signature integrity; self-protection; communications & data exchange; supply chain; advanced actor techniques; user-facing threats) and for each threat, list the possible affected **assets/components** (e.g., Signature DB, Update System, Sandbox, Quarantine, Telemetry).

Then, select risk factors and context modifiers. For the chosen UC, rate **RF1 - RF6** (i.e., size, maintenance know-how, data sensitivity, remote work, public Wi-Fi, removable media) to reflect exposure and they will act as **multipliers** or **weights** when estimating the likelihood and magnitude values.

B.4 Risk criteria

This clause sets the risk criteria and scales used by the methodology, including qualitative categories and their numeric mappings, the risk matrix, and aggregation rules. These criteria enable consistent and comparable estimation across use cases and product variants.

B.4.1 Risk Likelihood (L)

L expresses the estimated chance that a given risk factor for a UC will be avoid the product's operational objective. Table B.1 presents the proposed mapping between identified categories and their values.

Table B.1: L qualitative categories and numeric mapping

Category	Description (indicative frequency)*	Value
Rare	threat requires multiple preconditions; strong controls; limited exposure.	1
Unlikely	feasible but constrained by environment or controls.	2
Possible	routinely observed in similar deployments.	3
Likely	common in sector; known active adversaries.	4
Almost certain	continuously attempted in large populations.	5
NOTE: Calibrators for L: external exposure (internet, public Wi-Fi), user privilege, patch/update practice (RF2), mobile/remote use (RF4, RF5), removable media (RF6), organization size/attractiveness (RF1).		

B.4.2 Magnitude of loss or disruption (M)

M expresses the worst credible level of adverse consequence if the scenario occurs. Assess impact across confidentiality, integrity, availability, and compliance/reputation, and take the highest applicable dimension. Consider blast radius, persistence/duration of effects, propagation potential, impact on safety/critical services, legal/reporting obligations, and recovery effort/cost. Table B.2 presents the proposed mapping between identified categories and their values.

Table B.2: M qualitative categories and numeric mapping

Category	Illustrative consequence for PwDE / environment	Value
Negligible	No data/ops impact and no material loss; transient, auto-recoverable.	1
Minor	Localized user disruption; recoverable quickly; user inconvenience; no data at risk	2
Moderate	Service interruption or privacy event requiring incident handling	3
Major	Material service outage, significant data exposure, or regulatory notification, quarantines/updates disabled.	4
Severe	Safety/public-service impact, widespread outage, or large-scale data compromise; legal/reporting impact.	5

B.4.3 Qualitative risk matrix

The qualitative risk matrix maps the L of a threat scenario (rows) against the M (columns) and yields a risk category: Low (L), Moderate (M), Significant (S), High (H), or Very High (VH). It provides a fast, defensible determination

before (or alongside) any quantitative scoring as the risk category is determined by plotting (L,M). Manufacturers should adopt thresholds no less stringent than the following baseline.

Table B.3

	M=1	M=2	M=3	M=4	M=5
L=1	L	L	M	M	S
L=2	L	L	M	S	H
L=3	L	M	S	H	H
L=4	M	M	S	H	VH
L=5	M	S	H	VH	VH

B.4.4 Quantitative scoring and aggregation

- Assign numeric values to L and M as in clauses B.3.1 and B.3.2.
- **Inherent Risk Score** (R_{inh}):
 - $R_{inh} = L \times M$ (range 1 to 25).
- **Context Multiplier** (CM):
 - Reflect RF1–RF6 combined effect for the UC, typically $CM = 0.9 - 1.3$.
 - Example mapping:
 - Small org with low know-how (RF1 small, RF2 high): $CM \approx 1.2$;
 - Air-gapped trusted VM (UC1) with trained admins: $CM \approx 0.9$.
- Estimate **Control Effectiveness** (CE):
 - Range 0.6 (i.e., strong, verified control suite) to 1.0 (i.e., no mitigating control yet).
 - CE is supported by assessment evidence in Clause 6 (e.g., signed-update design, pen-tests, logging, SBOM).
- Compute **Residual Risk Score** (R_{res}):
 - $R_{res} = R_{inh} \times CM \times CE$
- Map R_{res} to categories:
 - Low (1 - 4), Moderate (5 - 9), Significant (10 - 14), High (15 - 19), Very High (20 - 25).
- Map categories to SCL:
 - Low (Minimal SCL), Moderate/Significant (Medium SCL) and High/Very High (High SCL)
 - Optionally, manufacturers may declare Custom SCL for UC5, explicitly listing borrowed controls from higher SCLs.
 - Tie the SCL decision to the draft's security requirement sets (Clause 5): e.g., High SCL triggers stronger expectations for signed updates, tamper-resistant logs, MFA/RBAC, sandbox defaults, etc., and corresponding assessment evidence in Clause 6.

B.5 Process:

The following lines provide the stepwise process to apply the methodology from scoping to review by specifying the required inputs, activities, and outputs for each step to ensure repeatability, traceability, and decision transparency. The steps of the implemented methodology are described to be applied by manufacturers to assess the risks and validate the requirements:

- 1) **Define the Object of Assessment (OoA) and Context:** Consider as the OoA the PwDE subsystems and its deployment environment (i.e., functional modules and operational context) and select the applicable UC.
- 2) **Identify threats:** Use the present document threat families (clause 4.4) as the baseline list, and for each threat, list affected assets/components (Clause 4.7).
- 3) **Select risk factors and context modifiers:** For the chosen UC, rate the RFs (Clause 4.5) to reflect exposure. These act as multipliers or weights when estimating likelihood/magnitude.
- 4) **Score Likelihood (L) and Magnitude (M):** Select L and M values based on selected UC and threat
- 5) **Compute inherent and residual risk:** Apply formulas in B4.4
- 6) **Risk Classification:** Determine qualitative category and SCL via B.4.4.
- 7) **Aggregate and map to SCL & requirements** Aggregate per-threat residual risks to a use-case profile using the 90th percentile (robust against outliers) or the top-N average for the highest 3 threats.
- 8) **Record evidence and traceability:** For each scored control, reference the assessment artefacts the draft already foresees (policies, update-signing design, pen-test reports, logs, SBOMs, disclosure policies), maintaining requirement → control → evidence traceability as required in Clause 6.

B.6 CM & CE calibration by use case and security level

B.6.1 About the CM

CM scales risk up or down based on the deployment context captured by the draft's RFs (Clause 4.5), translating the selected UC and its environment-specific exposure into a single numeric factor applied to $L \times M$. The point of using CM is because L and M alone ignore certain contextual differences (e.g., where does the PwDE runs: roaming laptops using public Wi-Fi or in a locked-down room). For this reason, the objective of CM is to consider these contextual differences in via the RFs.

CM value range follows the next conditions: a) $CM > 1$ increases risk due to harsher context and b) $CM < 1$ reduces it in safer, well-bounded contexts. Based on this, the proposed range in the present document and for the documented UCs is 0,9 – 1,2 (typical values) and with the possibility to allow 0,7 – 1,3 for well-justified extremes. Following the typical values, the proposed default CM calibration for the identified UCs is set as follows:

- 0,9 – UC1 trusted or resource-constrained systems, on-prem, no public Wi-Fi, no removable media, dedicated admins (RF4/RF5/RF6 low).
- 1,0 – UC3 well-secured systems in closed and restricted physical access with high know-how, no public Wi-Fi and no removable media (RF2/RF5/RF6 low).
- 1,1 – UC2 general endpoints with mixed user skill, regular internet use, some public Wi-Fi or USB exposure (RF2/RF5/RF6 moderate).
- 1,2 – UC4/UC6 roaming laptops or mobiles with frequent public Wi-Fi, heavy remote work, app-store/sideload risks (RF4/RF5 high).
- Custom – UC5 deeply integrated environments may get 1.1 due to larger integration surface (APIs/feeds).

Finally, when applying this methodology, a PwDE manufacturer should trace the selected CM to RF notes in its risk register (e.g., "RF4 high; RF5 high; RF6 medium → $CM=1,2$ ").

B6.2 About the CE

CE is a damping factor that represents how well the implemented controls (Clause 5) actually reduce risk in this product and environment, backed by the assessment evidence in Clause 6. The reason to use the CE is the fact that two products

can face the same threats and context, but they may differ vastly in aspects such as in signed-update design, self-protection, logging, MFA, etc. To this end, the CE captures control strength and verification.

CE value range follows the next conditions: a) 1,0 means *no* meaningful mitigation yet and b) lower CE values are better (e.g., 0,7 for strong, verified controls). Based on this the proposed range is between 0,6 and 1, with the CE calibration as follows:

- 0,6 – 0,7: Strong, layered controls with evidence.
- 0,75 – 0,85: Good controls present but with gaps (partial coverage, limited testing, or pending hardening).
- 0,9 – 1,0: Controls missing, immature, or unevidenced (design intent only, no verification yet).

In order to justify the selected CE value, it is key to cite the requirement IDs (Clause 5) and the specific evidence types from Clause 6 (e.g., designs, configs, logs, test reports, SBOMs).

B.7 Example

The following text aims to illustrate an example of how the previous methodology should be applied to based on the threats and requirements presented in the present document.

Scenario: UC3 - High-risk Server Environments.

Threat: Compromised Update Packages (MITM/rogue feed).

Components: Update System, Signature DB, Comms.

Controls: vendor-signed updates, TLS pinning, rollback protection, TUF-like workflow, allow-list of update domains, tamper-resistant logs (REQ-SU-02/03/04/06, REQ-INT-01/04, REQ-LOG-03)

Computed values:

- $L = 3$ (Possible) $\rightarrow$ Attackers target vendors; enterprise controls reduce exposure.
- $M = 5$ (Severe) $\rightarrow$ Poisoned updates can disable detection across fleet.
- $CM = 1,0$ $\rightarrow$ RF context: enterprise, high know-how (RF2 good), no public Wi-Fi, no removable media.
- Inherent risk: $R_{inh} = 3 \times 5 = 15$ (Significant).
- $CE = 0,7$ $\rightarrow$ Based on identified controls.
- Residual risk: $R_{res} = 15 \times 1,0 \times 0,7 = 10,5$ (High)

Decision: Map to High SCL for UC3; ensure full set of high-tier controls are implemented and evidenced per Clause 6.

If manufacturers aim to apply the presented methodology, it is key to identify, for each threat-related scenario, to collect the evidences necessary to estimate the right CE and support Annex A traceability. Manufacturers may embed this methodology in their secure development lifecycle and re-run it for major updates, environment changes, or new threats (e.g. novel fileless techniques).

Note to editors: Cross-references to **Clauses 4.3, 4.4, 4.5, 4.6, 4.7, 4.8, 4.9, 5 and 6** were used to ensure coherence between the risk methodology, the threat landscape, the architectural scope, and the assessment criteria of the present document.

Annex C (informative): Use Cases Risk Assessment

This annex demonstrates the risk assessment done for each UC (clause 4.5.1) by using the identified threats (clause 4.4) as risk factors, the obtained value allows to determine the risk level of each use case and to determine the corresponding SCL (clause 4.3).

C.1 UC1: Systems with Performance Constraints or Trusted Environments

Representative Threat	L	M	CM	CE rationale (controls Clause 5 / assessed in Clause 6)	CE	Residual Risk	Risk Classification
Disabling/Bypassing Protection Modules (4.4.2)	2	3	0,9	Self-protection, PoLP, RBAC/MFA (REQ-SBD-01/03; REQ-AAC-06/07/08). Evidence via configs/tests.	0,8	4,32	Moderate
Rollback Attacks on Updates (4.4.1)	2	3	0,9	Signed updates, rollback protection (REQ-INT-01/04; REQ-CON-01/03). Test reports.	0,7	3,78	Low
MITM on Backend Links (4.4.3)	2	3	0,9	TLS/pinning (REQ-INT-02). Logs of verification.	0,9	4,86	Moderate

C.2 UC2: General-purpose Environments

Representative Threat	L	M	CM	CE rationale (controls Clause 5 / assessed in Clause 6)	CE	Residual Risk	Risk Classification
Social Engineering to Disable Protection (4.4.6)	4	3	1,1	Tamper/self-protection; secure defaults; RBAC/MFA (REQ-SBD-01; REQ-SDC-02; REQ-AAC-06/07/08).	0,8	10,56	Significant
MITM on Cloud Connections (4.4.3)	3	4	1,1	TLS/pinning; trusted update channel (REQ-INT-01/02; REQ-CON-01/03).	0,75	9,90	Moderate
Evasion Attacks (4.4.5)	3	4	1,1	Behaviour+sandbox (REQ-SDC-04/05; REQ-SBD-06/07).	0,85	11,22	Significant

C.3 High-risk Servers Environments

Representative Threat	L	M	CM	CE rationale (controls Clause 5 / assessed in Clause 6)	CE	Residual Risk	Risk Classification
Compromised Update Packages (4.4.1)	3	5	1,0	Signed updates, pinning, rollback, allow-lists, tamper-resistant logs (REQ-INT-01/04; REQ-LOG-03).	0,7	10,50	Significant
Privilege Escalation on PwDE Services (4.4.2)	3	5	1,0	Hardening, least-privilege drivers, code integrity (REQ-SBD-03/05; REQ-INT-03).	0,75	11,25	Significant
Leakage of Sensitive Data (4.4.3)	2	4	1,0	Encrypt in transit/at rest; minimization (REQ-INT-02; REQ-CON-02/04/05).	0,85	6,80	Moderate

C.4 High-risk Laptops Environments

Representative Threat	L	M	CM	CE rationale (controls Clause 5 / assessed in Clause 6)	CE	Residual Risk	Risk Classification
Social Engineering to Disable Protection (4.4.6)	4	4	1,2	Tamper & MFA; secure defaults (REQ-SBD-01; REQ-AAC-07/08; REQ-SDC-02/03).	0,8	15,36	High
Trojanized Distribution Channels (4.4.4)	3	5	1,2	Signed installers; source allow-list; SBOM (REQ-INT-01/04; REQ-LOG-03).	0,75	13,50	Significant
Telemetry/Log Exposure (4.4.3)	3	4	1,2	Encryption; privacy controls (REQ-CON-02/04/05; REQ-INT-02).	0,85	12,24	Significant

C.5 Tailored Environments

Representative Threat	L	M	CM	CE rationale (controls Clause 5 / assessed in Clause 6)	CE	Residual Risk	Risk Classification
Compromised Threat-Intel Feeds (4.4.3)	3	4	1,1	Feed auth/validation & pinning; provenance logging (REQ-INT-01/02; REQ-LOG-02/04).	0,8	10,56	Significant
Management/API Abuse (4.4.2)	3	4	1,1	RBAC/MFA/least privilege; API hardening (REQ-AAC-06/07/08; REQ-SBD-03).	0,75	9,90	Moderate
SBOM Manipulation (4.4.4)	2	3	1,1	Signed artifacts; SBOM generation (REQ-INT-01/04; REQ-LOG-03).	0,8	5,28	Moderate

C.6 Mobile Phones

Representative Threat	L	M	CM	CE rationale (controls Clause 5 / assessed in Clause 6)	CE	Residual Risk	Risk Classification
Malicious SDKs / Privilege Abuse (4.4.4/4.4.5)	4	4	1,2	Mobile-oriented sandbox defaults; runtime permission guards; minimization (REQ-SBD-06/07; REQ-CON-04/05).	0,85	16,32	High
Risky Wi-Fi / MITM to Backend (4.4.3)	4	3	1,2	TLS pinning; secure update transport (REQ-INT-02/01; REQ-CON-01/03).	0,8	11,52	Significant
Untrusted Application Distributor / Sideload Supply Chain (4.4.4)	3	4	1,2	Signed packages; store-policy compliance; allow-listing (REQ-INT-01/04; REQ-SDC-02).	0,8	11,52	Significant

Annex D (informative): Current virus and malware examples

This informative annex presents a definition of the current known examples of programming virus and malware known in the market:

Computer Viruses

Program viruses: A program virus becomes active when the program file (usually with extensions .BIN, .COM, .EXE, .OVL, .DRV) carrying the virus is opened. Once active, the virus will make copies of itself and will infect other programs on the computer.

Boot Sector viruses: A boot sector virus infects the first sector (boot) of diskettes and hard drives as this sector the Master Boot Record (MBR), which reads and loads the operating system (e.g. a virus infecting the MBR of a disk, the hard drive can become infected).

Multipartite viruses: A multipartite virus is a hybrid of a Boot Sector and Program viruses that infects program files and when the infected program is active, it will affect the boot record. By doing so, the next time the infected machine is started, the local drive and other programs on your computer will be infected.

Stealth viruses: A stealth virus disguises itself by implementing strategies to prevent being detected by antivirus software such as altering its file size, concealing itself in memory, etc.

Polymorphic viruses: This kind of virus bases its strength on changing its signature (i.e. binary pattern) every time it multiplies and infects a new file, making it difficult for its detection.

Macro Viruses: A macro virus is programmed as a macro embedded in a document, affecting every new document produced.

Malware

Ransomware: Malware designed to lock users out of their system or deny access to data until a ransom is paid.

Crypto-malware: A type of ransomware that encrypts user files and requires payment by a specific deadline and often through a digital currency.

Fileless Malware: Malware that makes changes to files that are native to the operating system, such as PowerShell or WMI. Because the operating system recognizes the edited files as legitimate, a fileless attack is not caught by antivirus software, becoming a bigger threat.

Spyware: Malware that collects information about users' activities without their knowledge or consent. This can include passwords, pins, payment information and unstructured messages.

Adware: Malware that tracks a user's surfing activity to determine which ads to serve them. This malware does not install any software on a user's computer. Its danger is the erosion of a user's privacy by capturing its data towards the creation of the user's profile for more complex security threats.

Trojans: Malware that disguises itself as desirable code or software and once it is downloaded without any warn from the user's side, it can take control of the victims' systems for malicious purposes.

Worms: Malware that targets vulnerabilities in operating systems to install themselves into networks. They may gain access in several ways (e.g. software backdoors, unintentional software vulnerabilities, etc.). Worms can be used by malicious actors to launch DDoS attacks, steal sensitive data, or conduct ransomware attacks.

Rootkits: Malware that gives malicious actors remote control of a victim's computer with full administrative privileges by being injected into applications, kernels, hypervisors, or firmware.

Keyloggers: Keyloggers have legitimate uses (e.g. a business monitoring its employees' activity), but when installed for malicious purposes, keyloggers can be used to steal password data, banking information and other sensitive information.

Bots (and botnets): Malware that performs automated tasks on command, normally used for legitimate purposes (e.g. indexing search engines), but when used for malicious purposes, they take the form of self-propagating malware that can connect back to a central server. Usually, bots are used in large numbers to create a botnet, which is a network of bots used to launch broad remotely-controlled floods of attacks (e.g. DDoS attacks).

Wiper Malware: Malware that erases the user's data and ensures it cannot be recovered with the objective to take down computer networks in (public/private) companies across but also to cover any traces left due to other possible cybersecurity threats such as an intrusion in order to weaken the victim's ability to respond.

Logic Bomb: Malware that is only activated under a specific condition (e.g. a pre-defined time or the x iteration of a process) to trigger a virus or worm into the system, usually damage from logic bombs varies from changing bytes of data to making hard drives unreadable.

Annex E (informative): Relationship between the present document and any related ETSI standards (if any)

This sub-cause identifies possible relationships between PwDE identified in the CRA [i.1]. The objective in this clause is to determine if the PwDE in the present document overlaps in some aspects or have dependencies with other PwDE requirements and how to proceed in that case:

Platform & OS layer → The PwDE in the present document is dependent on the underlying OS hosting it. Without an OS, the PwDE will not be able to perform. To this end, the PwDE manufacturer may take into account the requirements identified (WI OS XX) for the OSs available in the market and determine how its PwDE performs based on the OS. For example to validate that the OS where the PwDE relies on, is capable to provide a secure file management.

Firewall → While the PwDE in the present document focuses on the analysis of incoming files from the outside of the protected system domain, Firewalls (WI FI XX) focus on network traffic. These two PwDE may not collide among them but cooperate and so, no overlaps or dependencies are identified.

EDR/XDR → While the PwDE in the present document focuses its protection actions at file and process level, EDR/XDR watch endpoint activities such as network endpoints, email, cloud, etc.), for this reason these two PwDEs may complement each other. To this end, the EDR/XDR may use the data generated by the PwDE in the present document (e.g. malware family, infection method, risk rating, etc.) to incident reports or the PwDE in the present document may block obvious malware early, letting EDR/XDR focus on more complex, evasive and multi-stage threats. Additionally, manufacturers with a PwDE depending on the present document may check for possible requirements defined in (WI EDR/XDR XX).

SIEM and SOAR → The PwDE do not overlap with SIEM or SOAR but assist them on achieving a more secure domain by generating and feeding information related to malware threats (e.g. malware family/name, detection method, file data, etc.). With this data, SIEM may identify patterns and warn the SOAR to trigger reactive processes such as scanning or quarantine actions. Based on this, SIEM and SOAR-based PwDE manufacturers should take into account the requirements identified in the present document to properly offer their product on the market. Additionally, manufacturers with a PwDE depending on the present document may check for possible requirements defined in (WI SIEM XX).

BOOT MANAGERS → The PwDE present in the present document may have some ties with Boot Managers during the earliest parts of startup to anchor trust and spot tampering. In terms of dependencies, the PwDE presented in the present document depends on the boot chain for a verified start, early loading, and enforcement of driver signing; it also leverages TPM/attestation to confirm nothing altered the boot path. In return, the OS/boot sequence may rely on the PwDE to classify sensitive drivers conservatively, avoid breaking boot entries, and use supported APIs (not patching boot components). Both sides have to cooperate on recovery flows and cleanup of temporary boot entries to keep systems stable and trustworthy. Based on these possible dependencies, PwDE manufacturers may check the security requirements in (WI BOOT XX) to ensure possible aspects not presented in the present document.

Annex F (informative): Bibliography

<Publication>: "<Title>".<Edition>. <Year>, <Issue designation>, <Page location>.

Annex F (informative): Change history

Version	Information about changes
0.0.1	- Defined initial structure of the document. - Defined the scope of the document. - Added initial content in Clause 4 on: - General information about the PwDE. - Essential Functionalities. - Security Levels - Identified Threats - Use cases - Drafted a generic architecture. - Users - Placeholder Annex A: Mapping between GR requirements and CRA. - Placeholder Annex B: Risk assessment methodology
0.0.2	- Redefined content in Clause 4 on: - Essential Functionalities. - Security Levels - Identified Threats - Use cases - Added initial content in Clause 5 on: - First set of security requirements.
0.0.3	- Redefined content in Clause 4 on: - General information about the PwDE. - Security Levels - Identified Threats - Updated generic architecture figure and added description. - Updated content in Clause 5 on: - Added new security requirements.
0.0.4	- Redefined content in Clause 4 on: - General information about the PwDE. - Security Levels description - Identified Threats - Use Cases introductions - Users introduction - Updated generic architecture figure and added description. - Removed subclause 4.7.1 and converted it into security requirements in Clause 5. - Updated content in Clause 5 on: - Added new security requirements. - Added content in ANNEX B: Risk analysis methodology
0.0.5	- Updated content in Clause 4 on: - Security Levels description - New Use Cases - Updated content in Clause 5 on: - New structure pre requirements to map UCs relationship. - Improved content in ANNEX B: Risk analysis methodology

History

Version	Date	Status
V0.0.1	June 2025	Initial structure of the document.
V0.0.2	July 2025	Clause 4 initial content.
V0.0.3	July 2025	Clause 4 update and Clause 5 initial content.
V0.0.4	August 2025	Clauses 4, 5 updated content and Annex B (Risk Analysis) added.
V0.0.5	September 2025	Updated content in Clauses 4, 5 and Annex B. New content in Clause 6.
V0.0.5	September 2025	Clean-up done by <i>editHelp!</i> E-mail: mailto:edithelp@etsi.org